COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.4 · An Overview of Malware

Mestre CyberSec · **Lesson 2.4 — An Overview of Malware** (6:06) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Malware = software malicioso. Categoriza: INTENÇÃO (spionagem, roubo, derrubar — DoS); FORMA (virus/worm/rootkit/trojan/keylogger/ransomware/stealer); ESCONDER (packer/compress/packing, polymorphic, metamorphic, fileless).

💡 Key Exam Highlights & Critical Concepts

- Fileless = roda na memória, não toca em disco — invisível pro AV
- Polymorphic/métamorphobic muda de forma — evita assinatura

🎯 Exam Tips & Typical CompTIA Scenarios

- 'malware without a file on disk' = fileless malware

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — An Overview of Malware)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Virus (N/A)
Malicious code that attaches to a legitimate host file or program and requires user execution or file sharing to spread.
⚠️ ***Exam Trap:*** *Precisa de um hospedeiro e de ação do usuário; não se auto-replica como um worm.*

• Worm (N/A)
Self-replicating malware that spreads across networks without requiring a host file or user interaction.
⚠️ ***Exam Trap:*** *Auto-replica e se propaga sozinho pela rede; a ausência de interação do usuário é a chave.*

• Trojan Horse (N/A)
Malware disguised as legitimate software, which users are tricked into installing; it does not self-replicate.
⚠️ ***Exam Trap:*** *Disfarce de programa legítimo; não se propaga sozinho como vírus ou worm.*

• Ransomware (N/A)
Malware that encrypts files or locks systems and demands payment for the decryption key or restoration.
⚠️ ***Exam Trap:*** *Criptografia de dados + resgate; backups offline são a principal mitigação.*

• Keylogger (N/A)
Malware or hardware that records keystrokes to capture credentials, personal data, or other sensitive information.
⚠️ ***Exam Trap:*** *Registra teclas; pode ser software ou hardware; associado a roubo de credenciais.*

• Rootkit (N/A)
Malware designed to gain privileged access and hide its presence and other malicious activities from the OS and security tools.
⚠️ ***Exam Trap:*** *Oculta a si mesmo e outras ameaças; detecção é difícil, muitas vezes exige boot externo ou ferramenta especializada.*

• Fileless Malware (N/A)
Malware that executes in memory using legitimate system tools or scripts without writing a traditional file to disk.

⚠️ ***Exam Trap:*** *Gatilho: 'malware without a file on disk' = fileless; difícil para antivírus baseado em arquivo.*

- **Polymorphic/Metamorphic Malware (N/A)**

Malware that changes its code or appearance to evade signature-based detection; polymorphic mutates but keeps core payload, metamorphic rewrites its entire code.

⚠️ ***Exam Trap:*** *Muda de forma para evitar assinaturas; polimórfico usa criptografia/mutação, metamórfico reescreve o código.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Delivery Mechanism vs. Payload

🏠 **Real-World Analogy:** Think of a courier delivering a cardboard box to your front porch. The delivery van, the uniformed driver, and the taped packaging represent the Delivery Mechanism (the phishing email, the lost USB drive, or an open network port exploit). What is packed inside the box — whether it is a legitimate gift or a timed explosive that detonates in your living room — is the Payload (the malicious code that wipes disks, encrypts files, or mines crypto). The courier only handles transit; the actual devastation depends entirely on the payload inside.

🔍 **Root Cause & Background:** The architectural separation between infection vectors and malicious execution fueled the rise of cybercrime syndicates (Crime-as-a-Service). 'Initial Access Brokers' specialize strictly in perimeter breach and malware staging (delivery), while dedicated ransomware crews purchase that foothold to detonate their destructive payloads. Defenses that analyze only the final payload overlook the ingress vulnerability that remains open to future intrusions.

🛡️ **GRC Auditor Perspective:** Auditors must verify comprehensive Defense-in-Depth architectures. Delivery vectors must be intercepted using Secure Email Gateways (SPF/DKIM/DMARC), perimeter WAFs, and simulated phishing training. To neutralize payloads if delivery succeeds, mandate EDR/XDR telemetry, enforce the Principle of Least Privilege (removing local administrator rights), and implement strict network segmentation.

⚠️ **How CompTIA Tests This:** Trigger: 'malicious component that executes the actual destructive objective such as encrypting databases or stealing credentials'. Answer: Payload. Trigger: 'technique or vector used to transmit and deploy malicious code onto the host'. Answer: Delivery Mechanism / Delivery Vector. Distractor alert: The deceptive email attachment is the delivery vehicle; the malicious binary executing post-infection is the payload.

📌 Indicators of Compromise (IoCs)

🏠 **Real-World Analogy:** When a burglar breaks into a home, they leave physical traces at the crime scene: muddy bootprints on the rug, fingerprints on the window pane, torn fabric snagged on the fence, and cigarette ash on the porch. Indicators of Compromise (IoCs) are the exact digital fingerprints left behind in cyberspace: a cryptographic hash (SHA-256) of a malicious file, an anomalous external IP contacted at 3:00 AM, or an unauthorized registry run key injected into the Windows operating system.

🔍 **Root Cause & Background:** Malware must interact with the underlying operating system and network stack to accomplish its objectives, inherently generating immutable forensic artifacts. Because threat actors reuse infrastructure and compiled tools across multiple targets, capturing these artifacts allows the global security community to rapidly identify and isolate ongoing intrusions.

🛡️ **GRC Auditor Perspective:** Audit automated threat intelligence ingestion into SIEM and EDR platforms using standardized protocols (STIX/TAXII). Ensure the Security Operations Center (SOC) conducts proactive Threat Hunting by querying historical log repositories against newly disclosed IoCs published by cybersecurity authorities (such as CISA, NIST, and regional CSIRTs).

⚠️ **How CompTIA Tests This:** Trigger: 'forensic artifacts such as file hashes, malicious domain names, IP addresses, or modified registry keys that provide evidence of an intrusion'. Answer: Indicators of Compromise (IoCs). Distractor alert: IoCs are reactive forensic evidence of breach activity; Indicators of Attack (IoAs) focus on real-time attacker intent and behavioral tradecraft.

📌 Command and Control (C2 / C&C) Servers and Beacons

🏠 **Real-World Analogy:** An undercover agent operating inside a government facility does not act independently; every 10 minutes they pull out a hidden two-way radio, transmit a one-second burst ('I am alive, awaiting mission orders') to remote headquarters across the border, and wait for instructions ('exfiltrate file blue'). The headquarters is the Command and Control (C2) server, and the routine transmission is the Beacon. If building security pinpoints and jams that radio frequency, the operative is stranded, blinded, and unable to transfer stolen intelligence.

🔍 **Root Cause & Background:** Attackers rarely anticipate the internal topology or stored data of a target machine during initial intrusion. A bidirectional communication channel is essential to stage secondary modules, dispatch arbitrary commands, and exfiltrate harvested records. To bypass egress firewall controls, attackers disguise this traffic as outbound HTTP, HTTPS, or DNS tunnels.

🛡️ **GRC Auditor Perspective:** Mandate outbound traffic inspection (TLS decryption and filtering on perimeter firewalls), DNS sinkholing/filtering (blocking Domain Generation Algorithms - DGAs and newly registered domains), and Network Detection and Response (NDR) baselines capable of identifying repetitive periodic heartbeats (beacons) with low jitter.

⚠️ **How CompTIA Tests This:** Trigger: 'infected internal workstation periodically establishes outbound encrypted sessions to an unknown external host to fetch malicious tasks'. Answer: Command and Control (C2) / Beaconing. Distractor alert: Firewalls block inbound connections by default, so malware always initiates outbound sessions to establish the reverse C2 channel.

📌 Polymorphic vs. Metamorphic Malware

🏠 **Real-World Analogy:** Polymorphic malware is like a fugitive who changes disguises every 10 minutes (swapping wigs, trench coats, sunglasses, and hats): externally they appear completely different at every corner (the hash and decryptor wrapper change), but beneath the disguise their body and organs remain unchanged. Metamorphic malware is like a shape-shifting sci-fi mutant: it physically reconstructs its internal biological architecture, swaps limb configurations, and mutates its internal engine at every step, making it impossible to recognize using static anatomical templates.

🔍 **Root Cause & Background:** Legacy antivirus tools relied exclusively on static signature matching (cryptographic hashes such as MD5/SHA-256). Malware authors engineered polymorphism (re-encrypting the payload with unique random keys and mutating decryption stubs) and metamorphism (integrated mutation engines that decompile, rearrange, and rewrite internal machine instructions using semantic equivalents) to render static hash-based detection completely obsolete.

🛡️ **GRC Auditor Perspective:** Classify pure signature-based antivirus engines as obsolete and non-compliant for critical asset protection. Mandate modern Endpoint Detection and Response (EDR) platforms equipped with sandbox emulation, heuristic analysis, and behavioral machine learning capable of flagging runtime actions regardless of binary obfuscation.

⚠️ **How CompTIA Tests This:** Trigger: 'malware evades signature-based antivirus by encrypting its payload with a unique key and modifying its decryptor code on each infection while underlying functionality is identical'. Answer: Polymorphic malware. If the scenario specifies: 'completely rewrites its own source code and binary structure on every iteration': Metamorphic malware.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Malicious component performing the actual damaging action (encrypting databases, exfiltrating data), distinct from the entry vector	**Payload**
Technique or pathway used to transport and deliver malware onto the victim endpoint (e.g., phishing attachment, drop USB)	**Delivery Mechanism / Vector**
Forensic artifacts including SHA-256 hashes, malicious domains, and altered registry keys evidencing a security breach	**Indicators of Compromise (IoCs)**
External server contacted by infected workstations via periodic beacons over HTTPS to retrieve instructions	**Command and Control (C2) Server**
Malware altering its encryption key and outer stub on each infection to bypass static hashes while preserving core function	**Polymorphic Malware**
Highly sophisticated malware that completely disassembles, rewrites, and mutates its own internal machine instructions	**Metamorphic Malware**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

An accounting employee opens an email attachment and enables macros when prompted. Days later, the security team finds that executable files on a shared department drive have been modified and that other users' workstations become infected only after they run those modified files. The malicious code does not spread by itself across the network. Which malware type best matches this behavior?

A) Worm

B) Virus

C) Rootkit

D) Ransomware

QUESTION 2 · EXAM SCENARIO

After a laptop is connected to a hospital's internal network, multiple unpatched workstations begin showing SMB connection attempts and become compromised within minutes. No email attachment or user download is involved, and the infection spreads continuously from host to host. Which malware type is most likely involved?

A) Virus

B) Worm

C) Trojan horse

D) Keylogger

QUESTION 3 · EXAM SCENARIO

An employee downloads a utility from a third-party website because it promises faster PDF conversion. The utility performs that task, but endpoint logs show it also creates a hidden service and connects to an external command-and-control server. It does not infect other files or spread to other hosts by itself. Which malware type best describes this utility?

A) Worm

B) Virus

C) Trojan horse

D) Ransomware

QUESTION 4 · EXAM SCENARIO

Several departments report that business documents now have unusual extensions and cannot be opened. A text file appears in each affected folder demanding cryptocurrency payment. File server shadow copies have been deleted, and the encryption process is still running on some hosts. Which malware type is most likely involved?

A) Rootkit

B) Ransomware

C) Fileless malware

D) Worm

QUESTION 5 · EXAM SCENARIO

A security analyst suspects a compromised Linux server, but standard administrative tools do not show the suspicious process, network connection, or user account. The malware appears to intercept system calls and alter kernel data structures to conceal its activity and persist after reboot. Which malware type best matches this description?

A) Keylogger

B) Rootkit

C) Trojan horse

D) Polymorphic virus

QUESTION 6 · EXAM SCENARIO

Employees in a call center report slow workstation performance. An investigation finds a background process capturing every keystroke, including login credentials and customer credit card numbers, and periodically sending the collected text to an external server. Which malware type is most directly indicated?

A) Keylogger

B) Rootkit

C) Ransomware

D) Worm

QUESTION 7 · EXAM SCENARIO

A malware sample is analyzed. Each time it infects a new system, the encrypted payload and part of the decryption routine are different, so signature-based detection fails. After execution, however, the core malicious behavior is the same. Which evasion technique is being used?

A) Packing

B) Polymorphic malware

C) Metamorphic malware

D) Fileless malware

QUESTION 8 · EXAM SCENARIO

During reverse engineering, analysts observe that each generation of a malware sample has completely different instruction sequences, API calls, and code layout, yet it performs the same credential-stealing function. No significant code block remains identical between samples. Which technique is most likely implemented?

A) Polymorphic malware

B) Metamorphic malware

C) Packing

D) Rootkit

QUESTION 9 · EXAM SCENARIO

An endpoint detection tool alerts on a Microsoft Word document that spawns PowerShell. The script downloads additional instructions, runs them directly in memory, and creates a WMI event subscription for persistence. Investigators find no malicious executable saved on disk. Which malware category best describes this activity?

A) Fileless malware

B) Virus

C) Worm

D) Trojan horse

QUESTION 10 · EXAM SCENARIO

A suspicious executable is submitted for analysis. It appears highly compressed, has few readable strings, and when run it unpacks additional code into memory before executing its payload. Signature-based antivirus engines do not detect the original file. Which malware-hiding technique is most likely being used?

A) Polymorphic malware

B) Metamorphic malware

C) Packing

D) Fileless malware

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Virus

A virus requires a host file and often user action to execute and spread; it infects files such as executables, and other systems are compromised when those infected files are run. A worm self-propagates across the network, a rootkit conceals activity, and ransomware encrypts data for extortion.

Question 2: Option B — Worm

A worm is self-replicating and can spread across networks without user interaction, often exploiting vulnerable services such as SMB. A virus normally needs a host file or user action, a Trojan relies on disguising itself as legitimate software, and a keylogger captures keystrokes rather than self-propagating.

Question 3: Option C — Trojan horse

A Trojan horse disguises itself as legitimate or useful software but performs malicious actions, such as creating a backdoor or contacting command-and-control infrastructure. It does not necessarily self-replicate like a worm or infect files like a virus, and this scenario does not describe encryption for extortion.

Question 4: Option B — Ransomware

Ransomware encrypts files or systems and demands payment, often deleting shadow copies to prevent easy recovery. Rootkits hide activity, fileless malware runs in memory, and worms self-propagate; none of those directly explain the ransom note and mass file encryption.

Question 5: Option B — Rootkit

A rootkit is designed to gain privileged access and hide its presence by modifying kernel structures, system calls, or administrative tools. A keylogger captures input, a Trojan disguises itself as useful software, and a polymorphic virus changes code to evade signatures, but hiding deep system activity is characteristic of a rootkit.

Question 6: Option A — Keylogger

A keylogger records keystrokes to steal sensitive information such as credentials and payment card data. The scenario does not describe file encryption, self-propagation, or deep system concealment, so keylogger is the most direct match.

Question 7: Option B — Polymorphic malware

Polymorphic malware changes its encryption or decryption routine and payload appearance with each infection while keeping the core functionality the same. Metamorphic malware rewrites its entire code, packing hides code through compression or encryption, and fileless malware executes in memory.

Question 8: Option B — Metamorphic malware

Metamorphic malware rewrites its own code entirely, changing instruction sequences and structure while preserving malicious functionality. Polymorphic malware typically mutates an encryption or decryption component, packing compresses or encrypts code, and a rootkit focuses on concealment and privilege.

Question 9: Option A — Fileless malware

Fileless malware uses legitimate system tools, scripts, and memory-resident execution, often leaving little or no executable file on disk. WMI subscriptions can provide persistence. A virus infects files, a worm self-propagates, and a Trojan disguises itself as useful software.

Question 10: Option C — Packing

Packing compresses or encrypts malware code to obscure strings and signatures, then unpacks the real payload into memory at runtime. Polymorphic and metamorphic techniques change code across infections, while fileless malware is characterized by memory-only execution without a dropped executable.